Quiz — Crypto hygiene

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

Complete after `../readings/crypto_hygiene.md`. Complete the quiz, then check the separate answer key.

1. Why does **HMAC** need a secret key that a bare hash does not — what attack succeeds against `sha256(message)` stored beside the message?

2. Why does **AEAD** authenticate associated data that it does not encrypt — what fails if you encrypt the body but leave headers forgeable?

3. Why does TLS present a server **certificate** instead of "just encrypting with a shared password" for public websites?

4. Why refuse nonce reuse / inventing a cipher in this kata — what concrete failure mode are you avoiding?

5. Scenario: A webhook HMAC secret never rotates and lives in the repo. Which lifecycle steps failed, and what goes wrong after a leak?

6. Scenario: A teammate proposes storing `sha256(api_key)` next to ciphertext "for integrity." What do you push back with?